INFORME DE SEGURIDAD DEL FRONTEND

PharmaSoft | Actividad Autónoma - Sesión 11 | Estudiante: Pari | 26/10/2026

C1. Resumen de la ejecución

Se registran 24 casos: 16 casos base de la guía, cuatro casos propios de grupos distintos y cuatro pruebas B-01 a B-04 para el aviso de expiración. Los resultados fueron contrastados con capturas de ejecución y consultas al código; no se marcaron como realizados los escenarios sin evidencia.

Grupo	Pasa	Parcial	Pendiente
Login	5	0	0
Sesión	5	0	0
Interceptor	3	1	0
Guards	2	0	0
Menú y acciones	3	0	0
401 / 403	1	0	0
Aviso sesión	0	0	4
TOTAL	19	1	4

Alcance: se verificaron las redirecciones a login y a 403, permisos del menú por rol, errores 401 y 403, persistencia de sessionStorage, expiración y desconexión del backend. Las verificaciones propias reaprovecharon acciones observadas y capturas de pruebas base.

Implementación revisada

El frontend incorporó una señal segundosRestantes, el indicador porVencer, un temporizador con limpieza al cerrar sesión y un componente de aviso. Se añadió la ruta protegida /mi-cuenta, el servicio obtenerPerfil() y la tabla de roles/permisos. La compilación ng build terminó exitosamente. El endpoint GET /api/v1/auth/me devolvió HTTP 200.

Restricciones de evidencia

I-01: se verificó Bearer en Productos y ausencia de Bearer en Login; la exclusión de solicitudes externas se examinó en auth-interceptor.ts pero no se ejecutó una petición externa. E-01: se comprobó el 403 mediante consola y sesión activa; queda pendiente el manejo visual de la SPA. B-01 a B-04: se dejaron pendientes por falta de prueba temporizada real con expiración de 3 minutos.

C2. Hallazgos y propuestas de mejora

H-01 | Sesión independiente entre pestañas | Media

Descripción y evidencia: S-04: después de cerrar sesión en la primera pestaña, la segunda seguía pudiendo abrir Productos. Evidencia: S-04.

Causa probable: Uso de sessionStorage por pestaña y ausencia de notificación entre contextos. Archivos probables: core/auth/auth-service.ts, layout/header/header.ts.

Corrección propuesta: Difundir logout usando BroadcastChannel y borrar sesión en otras pestañas. Mantener la validación de token del backend.

H-02 | Mensaje de conexión poco claro | Baja

Descripción y evidencia: I-02: al detener el backend, Productos mostró el texto técnico Failed to fetch, aunque la sesión permaneció abierta. Evidencia I-02.

Causa probable: Error de red mostrado directamente por el componente o servicio. Archivos probables: producto-list.ts y error-interceptor.ts.

Corrección propuesta: Presentar un mensaje legible en español; distinguir explícitamente red caída de HTTP 401.

H-03 | Campo de nombre no coincide con DTO | Baja

Descripción y evidencia: En /mi-cuenta el nombre se mostraba vacío a pesar de HTTP 200; la respuesta del servidor utiliza empleadoNombre. Evidencia captura de GET /auth/me.

Causa probable: Desajuste de la interfaz PerfilUsuario con la respuesta real. Archivo: core/auth/auth-service.ts, método obtenerPerfil().

Corrección propuesta: Mapear empleadoNombre a nombreCompleto al recibir el perfil y repetir la comprobación en navegador.

Nota de severidad

Estas observaciones no cambian automáticamente el estado PASA de pruebas cuyos resultados esperados admiten documentar un comportamiento; se tratan como oportunidades de mejora. No se presentan pruebas pendientes como superadas.

C3. Análisis de seguridad

1. ¿Por qué sigue siendo obligatorio validar permisos en el backend?

El menú, los guards y la directiva de Angular guían la interfaz, pero están bajo control del navegador. Una persona puede escribir una URL, editar el DOM o llamar a la API desde la consola. En E-01, un usuario VENDEDOR intentó realizar un DELETE sobre Productos y el servidor respondió 403 mientras la sesión seguía activa. Por eso la autorización efectiva debe aplicarse a cada operación en PharmaBackend y no depender únicamente de lo que muestra la SPA.

2. sessionStorage, localStorage y cookie HttpOnly

sessionStorage facilita que una pestaña conserve la sesión tras F5 y normalmente se elimina al terminarla; sin embargo, el JavaScript de la página puede leer el token y el cierre de una pestaña no cierra necesariamente las demás. localStorage persiste entre reinicios y amplía la exposición ante código malicioso en el mismo origen. Una cookie Secure y HttpOnly impide la lectura directa desde JavaScript, aunque necesita protección CSRF y configuración cuidadosa de SameSite. Para un sistema de botica optaría por una cookie HttpOnly segura, con sesiones cortas y controles CSRF, si el backend se adapta a ese esquema.

3. ¿Por qué 401 cierra sesión y 403 no?

HTTP 401 señala que no hay credenciales válidas, por ejemplo un JWT alterado o vencido; volver al login es coherente. HTTP 403 significa que la identidad es válida, pero no tiene permiso para la operación concreta. En E-01 se obtuvo 403 con la sesión todavía activa. Cerrar sesión por cada 403 frustraría a trabajadores que pueden usar otros módulos; mantener abierta una sesión inválida después de 401 permitiría una navegación confusa y errores repetidos.

4. Redirección abierta y returnUrl

Una redirección abierta ocurre cuando el parámetro de destino de una página de confianza puede llevar sin validación a un sitio externo. Esto facilita mensajes de phishing que parecen empezar en el dominio legítimo. En L-04 se probó un returnUrl con una URL externa y, tras el login, el navegador terminó en /inicio. La validación debe aceptar rutas relativas internas y rechazar dominios externos y rutas sospechosas; se aplica en el flujo de login y no en el backend.

Cierre y trazabilidad

Archivos relevantes: src/app/core/auth/auth-service.ts, src/app/core/interceptors/auth-interceptor.ts, src/app/core/interceptors/error-interceptor.ts, src/app/core/guards/, src/app/shared/components/aviso-sesion/, src/app/features/auth/pages/mi-cuenta/. La matriz con ID, pasos, resultados y nombres de evidencia se entrega en docs/matriz-seguridad-spa-s11.xlsx. Se debe verificar el funcionamiento temporizado de B-01 a B-04 y el requisito formal de commits en días distintos.